

Narrativa explicativa del marco GQM + PRAGMATIC

Cómo evitar que los indicadores SQUARE se conviertan en un zoológico de cifras

1. Por qué GQM: el antídoto contra la métrica sin causa

En seguridad, la tentación de inventar métricas es fuerte. Lo es aún más cuando se trata de requisitos de seguridad:

- ¿Cuántos tenemos?
- ¿Cuántas páginas ocupan?
- ¿Cuántas veces se reenvía el documento?

La metodología **Goal-Question-Metric (GQM)** nos obliga a empezar al revés: primero el **objetivo**, luego las **preguntas** y solo al final las **métricas**. Esto evita la proliferación de indicadores que brillan en dashboards pero nada aportan a las decisiones.

Aplicado al universo SQUARE y al contexto español, GQM hace algo muy simple y muy difícil: pregunta qué queremos lograr con los requisitos de seguridad a nivel país, sector y organización, y solo entonces se digna contar algo.

2. Tres objetivos, muchas preguntas, algunas métricas

Los objetivos que hemos propuesto no pretenden agotar el mapa, pero sí cubrir lo esencial:

- G1: madurez de la ingeniería de requisitos de seguridad.
- G2: alineamiento con gestión de riesgos y marcos normativos.
- G3: valor económico y mejora continua.

En torno a ellos orbitan preguntas que cualquier CISO experimentado ha formulado alguna vez, aunque no siempre haya tenido tiempo de escribirlas. Solo entonces aparecen las métricas: cobertura, calidad, trazabilidad, costes, beneficios, correlaciones.

El truco, si es que lo hay, consiste en aceptar que no todas las preguntas merecen una métrica, y no todas las métricas responden a una pregunta importante.

3. Entra PRAGMATIC: no todo lo que se cuenta cuenta

Una vez definidas las métricas, toca pasarles la prueba de estrés PRAGMATIC:

- ¿Predicen algo útil o son meros testigos del pasado?
- ¿Son relevantes para los objetivos que nos hemos marcado?
- ¿Sugieren acciones concretas o solo alimentan presentaciones?
- ¿Reflejan la realidad o los deseos de quien las reporta?
- ¿Son comprensibles para alguien que no vive pegado al SIEM?
- ¿Pueden medirse con cierta precisión y frecuencia razonable?

- ¿No son duplicados disfrazados de otras métricas?
- ¿Cuánto cuesta obtenerlas?

Este examen no es un trámite; es el momento de la verdad. Más vale descartar aquí métricas espectaculares pero inservibles que montar sobre ellas políticas públicas o decisiones estratégicas.

4. Lo que revela la matriz PRAGMATIC

La matriz elaborada nos da algunas pistas incómodas:

- Hay métricas muy sólidas y baratas, como la cobertura de funciones críticas o el número de activos críticos sin requisitos. Si esas cifras son pobres, la situación es grave sin necesidad de modelos sofisticados.
- Otras métricas brillan conceptualmente pero sufren en precisión, como los beneficios por incidentes evitados o el ROI fino de requisitos. Son excelentes para conversaciones estratégicas, pero exigen honestidad al explicar su grado de estimación.
- Algunas métricas son buenas brújulas internas pero difíciles de comunicar a la alta dirección sin traducirlas (por ejemplo, iteraciones de revisión).

La conclusión práctica es que conviene distinguir entre:

- Un **núcleo duro de métricas** para cuadro de mando, comunicación externa y comparativas.
- Un **conjunto de métricas de laboratorio** para análisis interno, modelos de madurez y estudios de caso.

5. De los indicadores al discurso político (y viceversa)

El marco GQM + PRAGMATIC no vive en el vacío. Debe dialogar con:

- La Estrategia Nacional de Ciberseguridad y sus objetivos declarados.
- Las obligaciones de NIS2 y ENS, que piden gestión de riesgos y medidas proporcionadas.
- Los informes de incidentes y vulnerabilidades (INCIBE, ENISA) que describen la superficie del problema.

Lo interesante es que los indicadores SQUARE, bien afinados, permiten contar otra historia: no solo cuántas cosas han salido mal, sino hasta qué punto habíamos diseñado con cariño los requisitos de seguridad de los sistemas que fallaron.

En otras palabras, pasar del relato de “hemos tenido X incidentes” al relato de “hemos pasado de un 30 % a un 70 % de funciones críticas con requisitos de seguridad claros y verificados, y eso se nota en la incidentología”.

6. El papel del ROI sin delirios de exactitud

Hablar de ROI en requisitos de seguridad es un arte peligroso:

- Si se promete demasiado, se pierde credibilidad.
- Si se cuantifica todo, se cae en una falsa exactitud.
- Si se evita el tema, la conversación nunca sale de la escala “gasto”.

La propuesta de este marco es más modesta:

- Reconocer que buena parte de los beneficios son estimaciones razonables, no certezas matemáticas.
- Utilizar las métricas económicas más como **herramientas de diálogo** que como veredictos.
- Combinar números y narrativas (“esta inversión en requisitos ha permitido reducir un 30 % los cambios tardíos por fallos de seguridad”).

El ROI deja de ser un oráculo infalible y se convierte en un argumento debidamente etiquetado como “estimación informada”.

7. Para qué sirve todo esto (además de llenar informes)

Si se aplica con cierta disciplina, el marco GQM + PRAGMATIC sobre indicadores SQUARE puede:

- Ayudar a los responsables nacionales a priorizar políticas: qué sectores necesitan más apoyo en requisitos, dónde falta trazabilidad, dónde hay cultura pero no métricas.
- Permitir a las organizaciones compararse consigo mismas en el tiempo y con sus pares, sin caer en rankings simplistas.
- Servir de base para investigaciones académicas serias sobre la relación entre madurez de requisitos y resultados de ciberseguridad.

En el mejor de los casos, contribuirá a que la frase “debemos mejorar la seguridad” se traduzca por fin en una secuencia inteligible de objetivos, preguntas y números bien escogidos.

8. Epílogo: la humildad de la métrica

Ningún marco, por elegante que parezca, puede capturar toda la complejidad de la seguridad en sistemas reales. El propio SQUARE lo sabe: al final, se trata de personas negociando requisitos bajo presión de plazos, presupuestos y política.

El esfuerzo aquí consiste en dotar a esas negociaciones de un lenguaje común y de algunas reglas de higiene métrica. Si los indicadores sirven para eso –y no solo para decorar memorias–, ya habrán cumplido un papel más que digno.